

Security Education, Training & Awareness (SETA)

The control that acts on people — and the one people most reliably work around.



This Week in Cybersecurity Management

01

Study Canvas
Module C

02

Prescribed
reading is pp.
104 to 106

03

OPTIONAL

Answer
discussion
questions on
Canvas, and
chat with peers

04

Attend
workshop

05

OPTIONAL

Continue
discussion with
peers on
Canvas

This week's workshop

PART A

Quiz

PART B

Q&A on this week's
content

PART C

Make posters for
SETA

Intended Learning Objectives

01

Appreciate why an effective SETA strategy is critical against social engineering attacks

02

Distinguish the attributes, objectives and methods of education, training and awareness

03

Identify the key steps in a SETA program and how they form a control

04

Identify at least three critical challenges to a successful SETA program

05

Appreciate the relationship between SETA and organisational culture

BEFORE WE START

You are the new SETA lead

You have just taken over security education, training and awareness at a firm of twelve thousand people. The technology is in good shape. The culture is not.

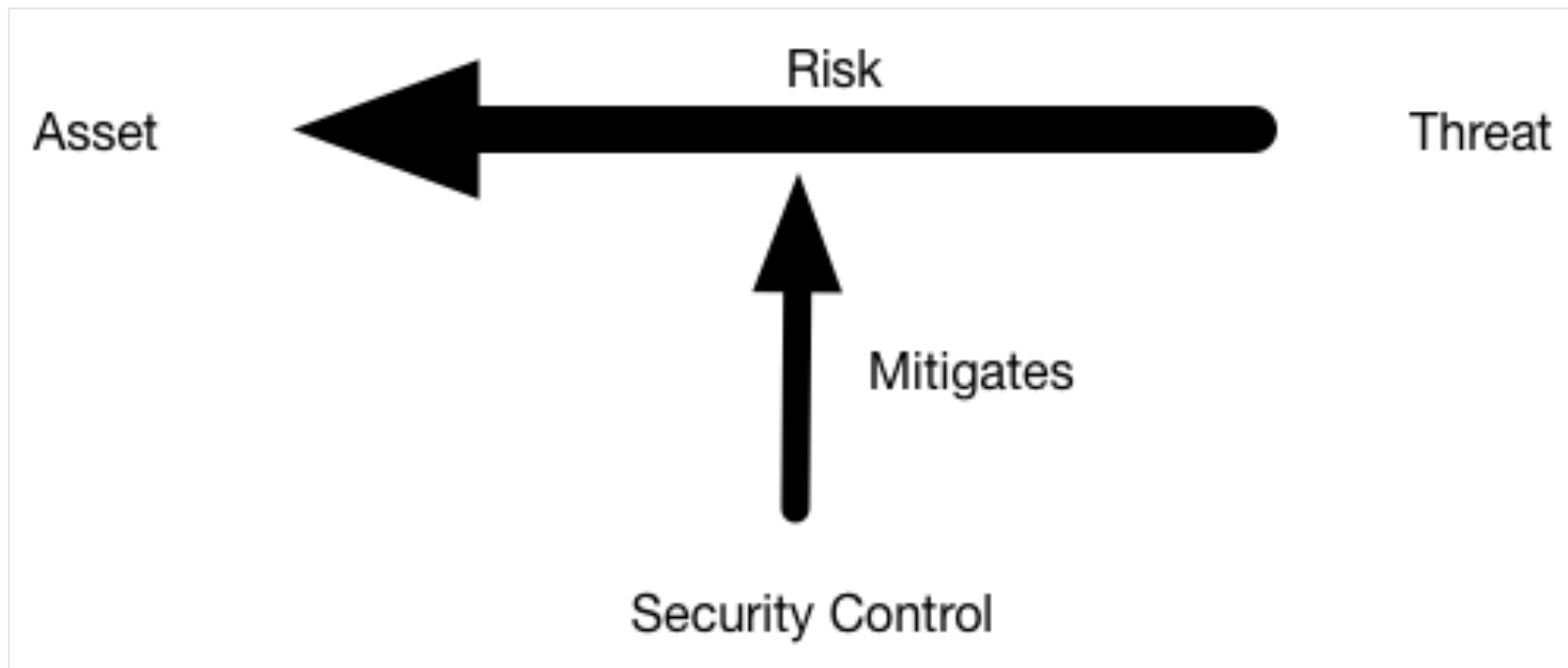
WHAT YOU HAVE WALKED INTO

- The annual module is clicked through, video muted
- Passwords are shared inside teams to avoid raising a ticket
- Phishing simulations get forwarded as a joke, not reported
- Doors are held for anyone even if they are carrying a laptop bag
- Security says no, so the workaround is the real process
- The last person who reported a security violation was blamed for it

One minute. Write down three to five things you would do to change this. Keep the list.

THE CORE SCAFFOLD

SETA is an informal managerial control for behavior change



Asset ← Risk ← Threat, with the security control mitigating the risk. SETA is one such control.

WHAT SETA IS FOR

The purpose of SETA

EDUCATION

Building in-depth knowledge

In-depth knowledge, as needed, to design, implement or operate security programs for organisations and systems.

TRAINING

Developing skills and knowledge

Skills and knowledge so that computer users can do their jobs while using IT systems more securely.

AWARENESS

Improving awareness

Awareness of the need to protect system resources, kept in front of people who are not thinking about security.

SETA is the control that works through people rather than around them.

THE COMPARATIVE FRAMEWORK

The elements of SETA

	Education	Training	Awareness
Attribute	Why	How	What
Level	Insight	Knowledge	Information
Objective	Understanding	Skill	Exposure
Teaching	Theoretical instruction	Practical instruction	Media
Method	· Discussion seminar · Background reading	· Lecture · Case study workshop · Hands-on practice	· Videos · Newsletters - Posters
Test measure	Essay (interpret learning)	Problem solving (apply learning)	· True or false · Multiple choice (identify learning)
Impact timeframe	Long term	Intermediate	Short term

Table recreated from Guttman, B & Roback, E 1995, An introduction to computer security: The NIST Handbook, Gaithersburg, MD, SP 800-12, p. 145.

What a good SETA program looks like

CURRENT

It uses the latest learning techniques and technologies.

SITUATED

It trains people in the workplace, rather than outside the organisation.

SMALL

Its workshops target a small number of individuals at a time.

SUSTAINED

It runs periodically over time, rather than in one short sharp burst.

Each of these is a design choice with a budget consequence. A program that meets all four is not the cheap option.

Seven steps in a SETA program

01 Identify program scope, goals and objectives

02 Identify training staff

03 Identify target audiences

04 Motivate management and employees

05 Administer the program

06 Maintain the program

07 Evaluate the program

Training by whom?

IN-HOUSE

By a specialist training team

Typically only large organisations have the resources to keep specialist trainers on staff.

INTERNAL, AD HOC

By non-specialist trainers

Cheap and available, but quality varies with whoever happens to be asked to run it.

EXTERNAL

By a party that charges

Bought-in expertise, priced accordingly, and rarely shaped to the organisation's own risks.

Training is typically conducted through one of these three approaches, and most organisations end up using more than one.

Customising the training

Training gives users detailed information and hands-on instruction so they can perform their duties securely. It is customised along two dimensions.

FUNCTIONAL BACKGROUND

- General user
- Managerial user
- Technical user

SKILL LEVEL

- Novice
- Intermediate
- Advanced

COMPARING THE OPTIONS

Delivery methods

Method	Strengths	Limits
One-on-one	Personal, informal, customised	Expensive
Formal class	Community learning, efficient, cost-effective	Not sufficiently responsive; difficult to schedule
Computer-based training	Flexible, self-paced, cost-effective	Software may be expensive; customisation limited
Distance learning and web seminars	Low cost	Customisation limited
User support group	Informal, interactive learning	—
On-the-job training	Applied learning, inexpensive	Learning curve involved
Self-study, non-computerised	Lowest cost, self-paced, self-managed	Shifts responsibility and quality onto the trainee

In practice budget, scheduling and the needs of the organisation usually decide first.

Developing awareness components

Many awareness components cost little or nothing. Others become very expensive once they are bought in from outside.

MADE IN-HOUSE

- Posters and banners
- Newsletters
- Bulletin boards
- Brochures and flyers

BOUGHT OR BOOKED

- Videos
- Computer-based training
- Lectures and conferences
- Trinkets — coffee cups, pens, pencils, T-shirts

The security newsletter

Keep security uppermost in users' minds, and stimulate them to care about it.

A cost-effective way to disseminate security information, in hard copy, by email or on the intranet. Topics can include threats to the organisation's information assets, schedules for upcoming security classes, and the addition of new security personnel.

WHAT A NEWSLETTER CARRIES

- Summaries of key policies
- Summaries of key news articles
- A calendar of security events — training sessions, presentations and other activities
- Announcements relevant to information security
- How-tos

The security poster

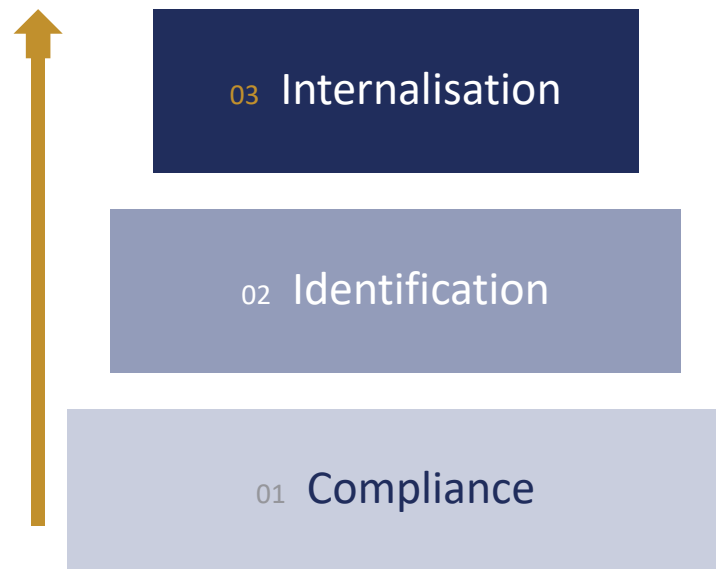
Simple, inexpensive, and easy to do badly.

A poster series keeps security on people's minds. Professional posters can be quite expensive, so in-house development is often the better solution — which is what this week's workshop asks you to do.

KEYS TO A GOOD POSTER SERIES

- 01 Vary the content and keep the posters updated
- 02 Keep them simple, but visually interesting
- 03 Make the message clear
- 04 Provide information on reporting violations

The Kelman Behaviour Change Model



Kelman, H.C. (1958). Compliance, identification and internalization: three processes of attitude change. *Journal of Conflict Resolution*, 2(1), 51–60.

YOU CANNOT SKIP A LEVEL

Compliance

People follow rules to avoid punishment. The change is temporary and superficial, and it needs constant monitoring. The moment supervision goes, so does the behaviour.

Identification

People follow the practice because of a relationship. They want to stay on good terms with a person so they go along with it.

Internalisation

People do it because it fits what they already believe.

Telstra: from awareness to influence

An in-depth case study of Telstra by Alshaikh and Adamson (2021). The second author led the cyber influence team, so the account comes from inside it.

WHERE IT STARTED

Until 2014 the awareness capability was entirely compliance-focused: policies, standards and an annual mandatory training module. Cyber was an IT issue, owned by security operations.

WHAT THE TEAM WAS FOR

A cyber influence team was set up in late 2014, on the view that cyber was as much about people as technology. The brief: move it from an IT problem to a business risk, and change behaviour rather than raise awareness.

WHO WAS IN IT

Six people, almost none of them technical. A lead with a political science degree and a career in stakeholder relations, two former technology journalists, a designer, a UX specialist and an administrator.

Their starting assumption, from the research: fear-based awareness does not change behaviour. Advice has to be targeted, actionable and doable.

How the champion network was built

INTEREST, NOT ROLE

Opt-in, and open to every level and department. Champions were chosen on enthusiasm rather than seniority. No pay, no promotion and no set time commitment, because demanding hours would have thinned the field.

“WHAT’S IN IT FOR THEM?”

The question the team say governed every decision. Members are surveyed routinely on what they want to know and how they want to be told, and the programme is rebuilt on those answers.

AUTOMATE, THEN SCALE

At around fifty members the administration had become one person’s full-time job. Registration, onboarding, training and service ordering were automated, and the network grew past five hundred.

Six people, acting as a force multiplier: five members became more than seven hundred, organically. Word of mouth is by far the biggest recruitment channel, and the team treat that rather than completion rates as their measure of success.

A security team you can order from

Once the administration was automated, champions could order three things for their own teams.

BRIEFINGS ON REQUEST

A champion orders a briefing for their team.
The influence team assigns the right specialist
— red team, penetration tester, risk expert,
analyst.

PHISHING DRILLS ON REQUEST

The champion picks the scenario and the
recipients. Results go back to the champion, so
the team discusses its own result rather than
receiving a report card.

A DAY IN THE SOC

A champion spends a day with the analysts,
watching threats handled in real time. Security
stops being an academic subject.

SEE HOW INNOVATIVE THIS IS

The security team became something the business orders from.

PULLING IT TOGETHER

Parting thoughts

Culture eats strategy for breakfast.

Culture is what is routine and acceptable in the organisation, not what is written in the policy or the training program.

THE QUESTION THAT MATTERS

Why are SETA programs so often ineffective?

FOUR CHALLENGES TO TAKE AWAY

It competes for attention

How much training do employees already do every year?

One size does not fit all

Can different generations, or a CEO and an analyst, be trained the same way?

Compliance drives the format

Online training is favoured for compliance reasons, but employees rush through with no intention of engaging.

Doing it properly is expensive

The version that changes behaviour is not the one that fits the budget.

BACK TO YOUR LIST

So what would you do now?

Take out your list.

Before you add anything, cross out whatever was awareness wearing the clothes of behaviour change.

THE TEST

Would anything on it still be happening in a year?

FIVE QUESTIONS TO PUT TO YOUR OWN LIST

Which level were you aiming at?

Compliance lasts as long as somebody is watching.

Who is the audience, exactly?

"All staff" is not an audience. Name the moment.

Who carries it?

Six people could not reach Telstra on their own.

What is in it for them?

If you cannot answer that, it is a message, not a programme.

How would you know?

Completion rates measure attendance, not behaviour.

Summary

Three things, one program

Education builds in-depth knowledge for those who design and run security programs.

Training develops the skills to use systems securely.

Awareness keeps the need to protect resources in front of everyone else.

Delivery is customized to the audience's role and skill level, and the tools run from videos and posters to newsletters and trinkets.

WHAT MAKES IT HOLD

Seven steps

Scope, staff, audiences, motivation, administration, maintenance, evaluation.

Ongoing evaluation

Maintenance and measurement are what keep a program effective after the launch.

Culture

The long-term determinant of whether any of it holds.

Q&A

Questions on SETA — and on why the control that targets people gets routed around.

